

Cracking delle Password e Sicurezza degli Hash

NECKER

18 novembre 2025

Indice

1	Perché il Cracking delle Password	2
1.1	La Funzione di Hash	2
2	John the Ripper (JtR): Strumento di Cracking	2
2.1	Modalità di Cracking di John the Ripper	2
3	Attacchi Precalcolati e Difesa: Rainbow Tables e Salting	3
3.1	Rainbow Tables	3
3.2	La Contromisura: Salting	3
4	Gestione delle Password sui Sistemi Linux	4
4.1	Formato Hash Salato in /etc/shadow	4
4.1.1	Esempio di Linea /etc/shadow (SHA-512)	5

1 Perché il Cracking delle Password

Il cracking delle password è una tecnica di analisi di sicurezza fondamentale, utilizzata sia dagli attaccanti per compromettere i sistemi, sia dai professionisti della sicurezza per testare la robustezza delle proprie difese.

- **Password Leakate:** Le credenziali rubate sono spesso *facilmente* reperibili online in seguito a **Data Breaches** o **server mal configurati**. Servizi come <https://haveibeenpwned.com/> permettono di verificare se una propria credenziale è stata compromessa.
- **Formato Dati:** Una password rubata non è solitamente memorizzata in chiaro (*cleartext*), ma nella sua forma cifrata (o pseudocifrata): l'**Hash**.

1.1 La Funzione di Hash

Una **funzione di hash** è un algoritmo matematico che prende un input (la password) di lunghezza variabile e produce un output (l'hash) di **lunghezza fissa**.

$$\text{Hash} = H(\text{Password})$$

Caratteristiche chiave:

- **A Senso Unico:** È facile calcolare l'hash dalla password, ma estremamente difficile risalire alla password partendo dall'hash (proprietà di preimmagine).
- **Deterministica:** La stessa password produce sempre lo stesso hash (se non viene utilizzato il Salt).

Esempio (ipotetico con SHA-256):

$$\text{matteo} \xrightarrow{H} \text{c612a8d03...}$$

2 John the Ripper (JtR): Strumento di Cracking

John the Ripper (JtR) è un software libero e open-source molto diffuso per il cracking delle password.

- **Funzionalità Integrata:** Combina una serie di cracker in un unico pacchetto.
- **Autodetect:** *Autodetects* il tipo di hash della password (anche se è sempre consigliato specificarlo ad esempio con la funzionalità integrata in kali linux: **hash-identifier** e poi specificandola in **JtR** con il parametro **-format**).
- **Versatilità:** Può essere eseguito contro vari formati di password cifrate e salate (come quelle di Linux, Windows, database, ecc.).

2.1 Modalità di Cracking di John the Ripper

- **Wordlist (Dizionario):** La modalità più semplice ed efficace. John prova a calcolare l'hash di ogni parola specificata in un file di dizionario (un file di testo contenente una parola per riga) e verifica la corrispondenza.

- **Single:** Utilizza le informazioni dell'utente (username, nome completo, ecc.) e applica regole di **mangling** (modifiche comuni come sostituzioni di caratteri, numeri aggiunti) come candidati password.
- **Incremental/Bruteforce (Forza Bruta):** La modalità più potente; tenta tutte le combinazioni possibili di caratteri. Non è garantito che termini mai (tempo di calcolo teoricamente infinito per password sufficientemente lunghe).
- **External:** Permette l'utilizzo di regole e algoritmi personalizzati per generare password da testare.

3 Attacchi Precalcolati e Difesa: Rainbow Tables e Salting

3.1 Rainbow Tables

Le **Rainbow Tables** sono un database pre-calcolato di hash. Per mitigare gli attacchi basati su **password non salate**:

- Le password e stringhe casuali vengono elaborate con la funzione di hash e la mappatura {input / hash} viene memorizzata.
- L'attaccante esegue una **ricerca inversa** diretta (*reverse lookup*) sull'hash rubato, saltando la fase di calcolo.
- **Vantaggio:** Velocità estrema.
- **Svantaggio:** Richiedono un'immensa quantità di spazio di archiviazione.

3.2 La Contromisura: Salting

Per annullare l'efficacia delle Rainbow Tables, si utilizza il **Salt** (Sale).

- **Definizione:** Il Salt è un valore **casuale** (di lunghezza fissa e crittograficamente forte) che viene **aggiunto** alla password prima del calcolo dell'hash.
- **Processo:** $\text{Hash} = H(\text{Password} + \text{Salt})$. Sia l'Hash che il Salt vengono memorizzati.
- **Efficacia:** Ogni password (anche le identiche) con un Salt diverso produce un Hash completamente differente. Ciò rende impraticabile precalcolare le Rainbow Tables, poiché sarebbe necessaria una tabella separata per ogni Salt possibile.

4 Gestione delle Password sui Sistemi Linux

I sistemi Linux separano le informazioni utente dalle password cifrate per motivi di sicurezza.

- **/etc/passwd:** File di testo leggibile da tutti (*world-readable*) che contiene le informazioni di base dell'utente. Nelle versioni moderne, la password viene sostituita con un segnaposto (es. x) per motivi di sicurezza.
- **/etc/shadow:** File di testo leggibile **solo dall'utente root** che contiene gli hash delle password e i dati di sicurezza (scadenza, ecc.).

4.1 Formato Hash Salato in /etc/shadow

Campo	Nome	Tipo di Dato	Descrizione
1	Nome Utente	Stringa	L'identificativo dell'account (es. madam).
2	Password Hash	Stringa complessa	Contiene l'hash della password. Il formato è \$id\$salt\$hash, dove \$id\$ indica l'algoritmo (es. \$6\$ per SHA-512).
3	Ultimo Cambio	Intero	Data in cui la password è stata cambiata l'ultima volta (in giorni trascorsi dal 1 Gennaio 1970, l'epoch Unix).
4	Giorni Minimi	Intero	Numero minimo di giorni che devono trascorrere prima che l'utente possa cambiare nuovamente la password.
5	Giorni Massimi	Intero	Numero massimo di giorni dopo i quali la password deve essere cambiata.
6	Giorni di Avviso	Intero	Numero di giorni prima della scadenza della password in cui l'utente riceverà un avviso.
7	Giorni Inattivi	Intero	Numero di giorni dopo la scadenza dell'account in cui l'account sarà disabilitato.
8	Data di Scadenza	Intero	Data (in giorni dall'epoch Unix) in cui l'intero account scadrà definitivamente.
9	Riservato	Stringa	Campo riservato per uso futuro (spesso vuoto).

Il formato dell'hash in /etc/shadow codifica tipo di hash, Salt e Hash finale:

```
username: $id$salt$hashed_password: ...
```

- **\$id**}: Indica l'algoritmo di hashing utilizzato. Ad esempio:
 - \$1\$ = MD5
 - \$5\$ = SHA-256
 - \$6\$ = SHA-512 (Standard moderno)

- **salt:** Il valore del Salt utilizzato, memorizzato in chiaro.
- **hashed_password:** Il risultato finale dell'hash.

4.1.1 Esempio di Linea /etc/shadow (SHA-512)

```
madam:$6$reRr06Pic/lkDt1E$6B8znS3dxYmn...
..95oeJmWxjlU.../1a.:1003:1003:Adam Miller:/home/madam:/bin/sh
```

In questo esempio:

- **Utente:** madam
- **Algoritmo:** \$6\$ (SHA-512)
- **Salt:** reRr06Pic/lkDt1E
- **Hash Cifrato:** 6B8znS3dxYmn95oeJmWxjlU...